Halcyon Health Data

CRM Decision Meetings: Build vs. Buy

Fictional meeting transcripts

Company context (invented)

Halcyon sells a clinical data analytics and care-coordination platform to about 70 hospital systems and clinics across the Southeast and Mid-Atlantic. It has 210 employees, about $48M in revenue, and is headquartered in Raleigh. Its "CRM" is a patchwork of shared spreadsheets, an aging contacts database, and a notes tool that nobody officially approved. Because Halcyon handles protected health information (PHI) for its customers, its contracts are full of Business Associate Agreements, subprocessor approval clauses, and US-only data residency requirements. Eighteen months ago a sales rep pasted a client's data-sharing summary into a free AI notes app. Compliance caught it within a week and nothing leaked, but nobody has forgotten it.

Attendees

- Marianne Okafor, CEO
- Dev Raghunathan, CTO
- Colt Brannigan, VP Sales
- Priya Lindqvist, CFO
- Tomás Ibarra, VP Customer Success
- Jen Whitaker, Chief Privacy & Compliance Officer

Meeting 1: Leadership Sync, "The CRM Thing"

Tuesday, Sept 22, 9:02 AM. Conference room B.

Marianne: Okay. I've put this off for a long time, and I'd like to stop. Colt, you lost the Northgate renewal conversation because nobody on your team knew their CISO had emailed us twice.

Colt: I want it noted that *I* knew. The system didn't know. That's different.

Priya: Colt, you can't be the system.

Colt: I've been the system for twenty-two years and we've done fine.

Marianne: We've done fine at $20 million. We're at $48. And what scares me isn't the missed email. It's that our customer relationships, our contract terms, and half the sensitive stuff about what data we touch for whom is scattered across places I couldn't list for you if you put a gun to my head.

Jen: I can list them. That's the problem. I've listed them, and it's a bad list.

Marianne: Say more.

Jen: Our CRM isn't a normal CRM. It's not just names and phone numbers. It's which health systems share which data sets with us, what their BAAs say, which ones prohibit certain subprocessors, support escalations with screenshots that occasionally have patient information in them even though they're not supposed to. Every one of our customers believes we treat that information the way they would. If a vendor holds it, we've just added somebody to the chain of custody.

Dev: So I'll say where I am, and I'll be honest, I'm leaning build. Not because it's fun. Okay, partly because it's fun. But mostly because I keep running into the same wall. Every SaaS CRM I look at wants our data in their multi-tenant cloud, with their support staff able to see it, and their subprocessors in places I can't always verify.

Priya: Can I push on that? Because I'm going to be the annoying person who argues the other side, and I'll tell you now that I might lose.

Marianne: Please. That's why you're here.

Priya: The serious CRM vendors have security teams bigger than our entire engineering org. They're SOC 2, many are HITRUST, some will sign BAAs. We have two developers who are also keeping the customer portal alive. I'm not convinced a custom build that Dev's team writes in between everything else is *safer* than a vendor who does nothing but defend this stuff all day.

Dev: That's a legitimate point, and I've lost sleep over it.

Priya: And the cost. Forty-five users on a good SaaS CRM, call it eighty to a hundred thousand a year. You're telling me a custom build is, what?

Dev: Rough guess, four hundred in year one, plus ongoing security work. And before you say it, yes, "ongoing" is the expensive word.

Priya: "Ongoing" is what I lie awake about. And key-person risk. If the one person who understands our custom CRM leaves, I'm explaining to the board why we have a $400K system that's a hostage situation.

Dev: I'm *right here.*

Priya: I like you. That's why I'm worried.

Colt: I'm going to say something that'll sound like I'm on Priya's side, and I'm not sure I am. I want a tool my reps will actually use. I don't care who builds it. But I've seen internal tools that look like they were designed by someone who's never sold anything. If Dev builds it, I want a rep sitting next to him.

Dev: Fair. Absolutely.

Tomás: Can I add the customer side? Because I think we sometimes talk about privacy like it's a compliance checkbox, and it isn't. When I talk to a hospital CISO, the first question isn't "what features do you have." It's "who else touches our data?" We've won deals because we could say "nobody but us, in our environment, in the US." That's not a talking point. It's *the* reason some of them chose us.

Jen: And it's in the contracts. Three of our biggest customers have clauses where we have to notify them before adding any subprocessor, and they can say no. If we put customer information in a vendor's cloud, that's potentially a subprocessor. I'd be sending notice letters to hospital legal departments about our *sales software*.

Marianne: That sounds painful.

Jen: It's worse than painful. One of them could simply say no, and then we're stuck with a tool we can't fully use.

Colt: Okay, but you're not saying every piece of the CRM is sensitive. My pipeline notes aren't PHI. My follow-up reminders aren't PHI.

Jen: Not by themselves. But the moment a rep pastes something into a notes field because it's convenient, it is. And we know that happens. We *know*, because it happened.

Colt: That was one guy.

Jen: That was one guy we caught.

[pause]

Marianne: Let me say what's worrying me, and it's not entirely rational. Eighteen months ago, when the notes app thing came up, I remember sitting in this room feeling like we'd gotten lucky. And I made a promise, mostly to myself, that we wouldn't get lucky again. That we'd build things so that being careful was the default instead of the exception.

Dev: That's what I keep coming back to. If it's ours, we can enforce it. Field-level encryption, our keys, our logging, no support engineer at a vendor with a backdoor into the admin panel.

Priya: Or you can buy a vendor that offers customer-managed keys and single-tenant hosting and *then* you don't have to maintain it.

Dev: If it exists. If they'll actually do it. I've seen "single-tenant" be a marketing phrase.

Priya: Then we make them prove it. Which is a reason to run the process, not skip it.

Marianne: I agree with that. I don't want a decision today. I want to find out whether a buy option exists that doesn't compromise what we promised our customers. If it does, I'll take it seriously. If it doesn't, we've learned something.

Jen: Can I set a floor, so nobody wastes time? If a vendor can't commit to US-only hosting, a signed BAA, customer-managed encryption keys, and a clean list of subprocessors we can disclose, I don't want to see the demo.

Marianne: Fair. Dev, find two or three vendors that clear Jen's floor. Priya, you're in every demo. Colt, you're in every demo with an open mind.

Colt: My mind is open. It's skeptical. Those coexist.

Meeting 2: Post-Demo Debrief

Thursday, Oct 15, 4:30 PM. Heavier mood than usual. Someone brought cookies and nobody ate them.

Marianne: Three demos. Where are we?

Tomás: I'll go first because I was surprised. Vendor B, the one that does healthcare-adjacent CRM, I liked it. The relationship timeline, the way it handled multi-stakeholder accounts. Hospital deals have like nine decision makers and it actually modeled that.

Colt: I'll admit it was good. I won't say "great." I'll say "good."

Priya: Colt, that's the highest compliment I've heard you give software.

Colt: I'm in a generous mood.

Dev: Here's the thing, though. When Jen asked about subprocessors, the answer came back as, and I wrote it down, "we use a small number of trusted partners for support and analytics." That is not a list.

Jen: It's not a list, no. And when I pressed, the rep said their support team in Dublin "may need occasional access" to troubleshoot.

Priya: Right, and I want to say something fairly here, because I don't want us to caricature the vendors. Vendor C came back the next day with an actual subprocessor list, offered single-tenant hosting in a US region, and said they'd support customer-managed keys. That's real. That is a vendor that cleared Jen's floor on paper.

Jen: On paper, yes. And I'll give them credit, the paper was good.

Priya: So the buy option isn't dead. It exists. It's more expensive than the base price, probably a hundred and forty a year once you add the single-tenant tier, but it exists.

Dev: And I still keep worrying about the part that's not on paper. Their engineers still operate the thing. If they get compromised, I'm reading about it from *their* press release, not discovering it in *my* logs.

Priya: And if *you* get compromised, you're reading about it in yours. And your team is two people.

Dev: Three, if I get the headcount.

Priya: Three people versus a security organization of a hundred and fifty. I'm not trying to be cruel. I'm trying to be honest about the risk we're taking on by building.

Dev: No, it's a fair hit. I've thought about it a lot. I just think the risk profile is different. A vendor is a bigger target. They hold a thousand companies' data. We'd hold ours. That's a more boring target.

Priya: Boring is good. I'm not going to argue that.

Marianne: Jen, where's your head?

Jen: Honestly? Conflicted. I'd *love* to say "build it, keep everything in-house, done." But I've been doing this long enough to know that in-house isn't automatically safe. In-house is where I find the unpatched server nobody remembers. In-house is where the notes app thing happened, in a way. The risk isn't only vendors. It's us being sloppy because we trust ourselves.

Colt: That might be the most honest thing anyone's said in this room.

Jen: I try.

Tomás: Can I ask the customer question? If we tell a hospital CISO "your relationship data lives in a vendor's cloud, but it's a great vendor," versus "it lives in our environment, under our keys, nobody else touches it," what does that sound like?

Marianne: The second one sounds like Halcyon.

Tomás: Right. And it's not a lie to say the first one's fine. It's just a different company. We'd be a company that says, "we trust our vendors." Which is *most* companies.

Colt: Which, again, isn't necessarily bad.

Tomás: No, I'm not saying it's bad. I'm saying it's not us.

[pause]

Colt: Can I say something? I've been quiet. I'm in sales. I'm the guy who'd normally say "just buy the thing and let me sell." And honestly, part of me still thinks that. Eight months of waiting for custom software while my reps are using spreadsheets, that costs me deals.

Dev: Seven months for the first usable version, and I'd want to ship the contact and account piece in four, so your reps get something real early.

Colt: Four's better than eight. But I need that written down somewhere that Priya can hold you to.

Priya: I will.

Colt: And I'll tell you what actually moved me. In Vendor C's demo, the rep joked that their admin could "see everything if you give them access." And I thought, why would I want anybody to be able to see my customers' stuff? I don't love that I felt that.

Marianne: Why not?

Colt: Because it's inconvenient. I wanted to buy something and be done. But I think I'm more protective of these customers than I thought. Some of these CISOs, I've known them for fifteen years. They trust me. They trust *us.* I'd feel like I was, I don't know, handing off something that isn't mine to hand off.

Priya: I respect that. I still think the cost is real, and I still think we're underestimating maintenance. But I'm hearing this room, and I'm hearing Jen, and I'm hearing what our customers pay us for.

Marianne: Let me try to say where I am. I think the buy option is genuinely viable. If we didn't have the contracts we have, if we didn't hold what we hold, I'd probably say buy, and I'd say it quickly. But our whole business is that health systems can hand us their data and sleep at night. If we can't give

them the same promise about our own records, then what are we selling?

Dev: I'd add, and this is me being a little self-critical, that I don't want to build because it's exciting. I want to build because the privacy case holds up even after Priya argues against it.

Priya: It holds up. I'm just going to make you prove it with a budget I can defend.

Marianne: Okay. Here's the shape I'd like us to explore. Build the core system that holds anything sensitive, in our own environment, with our own keys. Be strict about scope, no feature creep. And for anything that's not sensitive, like scheduling or marketing email, we buy. We don't build what we don't have to.

Dev: I can live with that. That's a better engineering decision, honestly.

Colt: Cautiously, I can live with that.

Priya: I can live with it if there are guardrails. A hard budget, a hard date, and a kill switch.

Marianne: Write those down. Priya, own the guardrails. Dev, give me a scoped plan. Jen, I want you embedded with Dev's team from day one, not at the end signing off.

Jen: Thank you. Honestly, thank you. That's the part that always goes wrong.

Meeting 3: Short Follow-Up

Monday, Nov 2, 8:15 AM. Standing meeting, ran 14 minutes.

Marianne: Where are we?

Dev: I have the scoped plan. Phase one is accounts, contacts, and the contract and BAA tracker, with field-level encryption and our own key management. Four months. Phase two is the pipeline and renewals views. We buy the email scheduling tool for anything outside the sensitive core, and Jen has already cleared it.

Jen: I cleared it with conditions. It never touches a field that could hold customer data. I wrote the rule and Dev's building it into the system so reps *can't* paste in the wrong place, instead of just being told not to.

Colt: I'll say that's the part I like. I don't have to be careful. The system is careful for me.

Priya: My guardrails, for the record. A hard cap of four hundred and twenty thousand for year one. If phase one slips past the end of March, we stop and re-evaluate buying Vendor C's single-tenant tier. I had a long call with them, they said they'd keep the offer open for ninety days, which I appreciated.

Dev: So I get one shot.

Priya: You get one shot with a net under it. Which is more than most people get.

Dev: I'll take it.

Tomás: For what it's worth, I'm already planning how I'd tell customers. Not as a feature, but as a sentence in the next security questionnaire. "Our own customer records are handled the same way we handle yours."

Marianne: I like that sentence.

Tomás: I stole it from Jen.

Jen: I accept royalties in cookies.

Colt: I'll be honest, I came into this wanting to buy something off the shelf. I'm leaving it still a little worried about the eight months. But I'd rather be a little worried and proud of how we did it than relieved and a little embarrassed.

Marianne: I think that's the most we can ask for.

Dev: And if I'm wrong about the build, Priya's net catches us. If I'm right, we have something nobody else has.

Priya: If you're wrong, I will say nothing, and I will think about it forever.

Dev: That's somehow worse.

Marianne: Okay. We're moving. Dev, kickoff next week. Jen, you're in the room. And nobody pastes anything into a notes app.

Jen: I'll be putting that on a poster.